

External Penetration Test Report — Spring 2026

Engagement summary

A two-week external and authenticated web application penetration test against the production platform, following OWASP ASVS L2 and the agreed rules of engagement. Focus areas: authentication (SSO and multi-factor auth), session management, the API gateway, and the billing endpoints.

Findings

ID	Severity	Finding	Status
PT-01	High	Rate limiting bypass via header spoofing on a legacy endpoint	Fixed during engagement
PT-02	Medium	Session fixation possible on the password-reset flow	Remediated, retest passed
PT-03	Medium	Verbose error responses leaked stack traces on malformed JSON	Remediated
PT-04	Low	Missing security headers on two static asset domains	Accepted risk, tracked

Retest

All high and medium findings were retested and confirmed fixed. The WAF ruleset was extended to detect the PT-01 bypass pattern, and vulnerability scanning signatures were updated. Evidence is archived with audit logging for SOC 2.